

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to explain how virtual NICs and virtual switches create east-west traffic that is invisible to physical network security controls, and describe how to address this gap.
- By the end of this lecture, you will be able to describe the VLAN hopping attack vector in virtualised network environments and explain the configuration settings that prevent it.
- By the end of this lecture, you will be able to identify the security risks associated with virtual storage, including data remnance, snapshot exposure, and the 2023 ESXiArgs ransomware campaign.
- By the end of this lecture, you will be able to explain the security implications of guest OS toolsets such as VMware Tools and Hyper-V Integration Services, including their privileged communication channel with the hypervisor.
- By the end of this lecture, you will be able to apply a layered security approach that treats each virtualisation abstraction layer as a distinct security boundary requiring its own controls.

Introduction

Virtual machines do not exist in isolation. They communicate with each other through virtual networks, store data on virtual disks backed by shared storage systems, and depend on software packages installed inside the guest operating system to function correctly in the virtualised environment. Each of these dependencies introduces a security boundary that exists entirely in software, invisible to the physical network inspection tools and storage auditing processes that traditional security programmes were designed around.

This lecture covers three distinct virtualisation layers below the application and operating system: virtual networking, virtual storage, and guest OS integration toolsets. In each case, the pattern is the same: virtualisation introduces an abstraction that creates new attack surface alongside its operational benefits, and that surface requires specific security controls that practitioners often overlook because they are not visible in the same way physical infrastructure is. The east-west traffic between VMs on the same host that never touches a physical switch, the snapshot file sitting outside the normal access control scope of a database, and the VMware Tools process running with elevated privileges inside a guest VM each represent security exposures that require deliberate attention.

The 2023 ESXiArgs ransomware campaign provides the most recent and consequential real-world example of what happens when virtual storage security is treated as a second-order concern. Ransomware operators who encrypted virtual disk files directly on the ESXi storage backend could affect every VM on a host without compromising individual guest operating systems. The storage layer, not the applications, was the target. Understanding this attack pattern and the controls that prevent it is directly relevant to both the CCSP examination and professional practice.

Core Concepts Explained

Virtual Network Adapters and East-West Traffic Security

Definition: Virtual NICs are software representations of physical network cards that connect VMs to virtual switches running inside the hypervisor host. Traffic between VMs on the same virtual switch moves entirely within the host server without touching the physical network, creating east-west traffic that is invisible to physical network security controls.

Business relevance: Traditional security architectures rely heavily on physical network inspection points, network taps, and inline intrusion detection systems. East-west traffic within a virtualised host bypasses all of these controls unless specific virtual networking configurations route traffic through inspection points.

Cloud Security Practitioner relevance: A Cloud Security Practitioner is responsible for ensuring that security monitoring tools have visibility into intra-host VM traffic through virtual switch port mirroring configuration, and that network segmentation between VM workloads is enforced through virtual VLAN policies rather than assumed from physical network separation.

Real-world example: A retail company running its e-commerce platform on a private cloud with a mix of web servers, application servers, and database servers on virtualised hosts discovered during a penetration test that an attacker who had compromised the web server VM could reach the database VM directly over the virtual switch without any traffic touching the physical network monitoring infrastructure. The company's IDS was positioned on the physical network and captured north-south traffic entering and leaving the host, but captured none of the direct VM-to-VM communication. The penetration tester used this invisible east-west path to conduct a SQL injection attack against the database from the compromised web server, exfiltrating 50,000 customer records without generating a single alert on the physical network monitoring tools. The remediation involved two changes: configuring the virtual switch to mirror all inter-VM traffic to a dedicated security monitoring VM running network analysis software, giving the security team visibility into the previously invisible east-west path; and implementing micro-segmentation using software-defined networking policies to enforce that web VMs can only reach application VMs on specific ports, with no direct path to database VMs. Both controls required changes only in virtual networking configuration, with no physical infrastructure changes.

Risks or limitations: The most common mistake is assuming that network segmentation enforced at the physical switch level prevents VM-to-VM communication on the same host. Physical segmentation is bypassed entirely by intra-host virtual switch communication. The best practice is to configure virtual VLAN policies and port groups to segment VM traffic at the virtual switch level, and to verify with traffic analysis that no unintended VM-to-VM paths exist.

VLAN Hopping in Virtual Environments

Definition: VLAN hopping is an attack where a malicious actor crafts network frames with VLAN tags for a network segment they should not have access to, tricking a switch configured in trunk mode into forwarding the frames to the target network.

Business relevance: In virtual environments, VLAN hopping can allow a compromised VM to communicate with VMs in a different VLAN that it is not permitted to reach, bypassing the network segmentation that the security architecture assumes is in place.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must verify that virtual switch port groups connected to guest VMs are configured in access mode, not trunk mode, and that native VLAN IDs are explicitly assigned to all ports rather than relying on defaults, to prevent VLAN hopping attacks.

Real-world example: In a multi-tenant hosting environment, a security researcher discovered in 2021 that the virtual switches connecting tenant VMs were configured with guest-facing ports in trunk mode rather than access mode. This configuration is sometimes used by administrators who want maximum flexibility in assigning VMs to VLANs without reconfiguring port settings, but it creates a VLAN hopping vulnerability. The researcher, operating from a guest VM that had been allocated to VLAN 100, crafted double-tagged Ethernet frames with an outer VLAN tag of 100 (the native VLAN of the trunk port) and an inner tag for VLAN 200 (a different tenant's VLAN). When the frame arrived at the trunk port, the outer tag was stripped (as expected for the native VLAN), and the inner VLAN 200 tag was processed as legitimate, forwarding the frame to the target VLAN 200 port group. The researcher was able to send one-directional traffic to another tenant's network segment without any authentication or authorisation. The remediation required changing all guest-facing virtual switch ports from trunk mode to access mode, which means each port only carries traffic for the VLAN explicitly assigned to it, and explicitly assigning non-default native VLAN IDs to all trunk links between virtual switches to prevent native VLAN tag stripping attacks.

Risks or limitations: Trunk mode on guest-facing virtual switch ports is the root configuration error that enables VLAN hopping. The best practice is to configure all guest VM-facing ports in access mode only, assign each port explicitly to a single VLAN, and use trunk mode only on uplinks between virtual switches or between virtual and physical switches where it is required.

Virtual Storage Security: Data Remnance and Snapshot Exposure

Definition: Virtual storage security encompasses the protection of virtual disk files, the secure deletion of storage volumes on deprovisioning, and the access control and encryption of VM snapshot files that capture the complete state of a virtual machine at a point in time.

Business relevance: Virtual disk files and snapshot files contain the same sensitive data as live running systems and require equivalent access control and encryption. Snapshot files sitting outside the normal production access control scope are a common source of uncontrolled sensitive data exposure.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must verify that cloud provider data deletion processes address storage remnance, that virtual disk encryption is applied at the storage backend level, that snapshot files are subject to the same access control policies as live disk files, and that snapshot policies include automated removal of snapshots that exceed a defined retention period.

Real-world example: The ESXiArgs ransomware campaign, observed beginning in February 2023, targeted VMware ESXi servers through exploitation of a heap overflow vulnerability (CVE-2021-21974) in the ESXi OpenSLP service. Rather than targeting individual guest virtual machines through their operating systems, the attackers encrypted the virtual disk files directly on the ESXi storage backend: the .vmrk, .vmx, .vmxf, .vmrd, and .nvram files that constitute a complete virtual machine. Because these files live on the storage layer beneath the guest OS, the attack did not need to compromise any guest operating system or application. One attack on the hypervisor storage layer simultaneously encrypted every VM on the affected host. Thousands of organisations running unpatched ESXi servers were affected. The attack illustrated three critical lessons: patching the hypervisor is not separable from patching the storage layer, because the hypervisor manages access to storage files; encryption of virtual disk files at rest limits the value of stolen disks but does not prevent an attacker with hypervisor-level access from encrypting what they can access; and backup copies stored on media not accessible through the compromised ESXi management interface were the primary recovery path for affected organisations. Organisations that had snapshot copies stored on isolated backup storage recovered faster than those whose snapshots were on the same ESXi storage backend the attackers had encrypted.

Risks or limitations: Storage remnance is a specific risk on deprovisioning: when a virtual disk is deleted or a cloud storage volume is released, the underlying storage blocks may not be immediately overwritten. A subsequent tenant allocated overlapping storage could theoretically recover data from the previous tenant. Cloud providers address this through secure deletion processes, but the CCSP exam expects candidates to know that verifying the provider's approach, rather than assuming it, is the customer's responsibility.

Guest OS Toolsets: VMware Tools and Hyper-V Integration Services

Definition: Guest OS toolsets are software packages installed inside virtual machines that improve integration between the guest operating system and the hypervisor. They include VMware Tools (or open-vm-tools in open-source contexts) and Microsoft Hyper-V Integration Services, and they run with elevated privileges while maintaining a direct communication channel to the hypervisor layer.

Business relevance: Guest OS toolsets provide operationally valuable functions including time synchronisation, application-consistent snapshot coordination, and performance improvements. Their direct privileged communication channel with the hypervisor also represents a potential attack surface if the toolset software is vulnerable or unpatched.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must ensure that guest OS toolset packages are included in the patch management programme, that the installed version is current across all VMs, that the toolset is removed from VMs where its functions are not required, and that the hypervisor-to-guest communication channel is monitored for anomalous activity.

Real-world example: In 2021, researchers published a series of vulnerabilities affecting VMware Tools (CVE-2021-21977 and related CVEs) that could be exploited by a malicious actor with guest OS access to send crafted messages through the VMware Tools communication channel toward the hypervisor layer. The channel, designed for legitimate functions like snapshot coordination and time synchronisation, does not travel over the network and therefore bypasses network-based security controls entirely. An exploit targeting this channel could potentially exfiltrate information or execute commands at the hypervisor level without any network traffic being generated that would appear in firewall or IDS logs. The remediation required updating VMware Tools to the patched version across all guest VMs, which in a large environment meant a phased update process touching hundreds or thousands of VMs. Organisations that had not inventoried which VMs had VMware Tools installed, or which version was running, had no way to prioritise the update effort. The incident highlighted the operational requirement to maintain an inventory of guest OS toolset installations with version tracking, not just an inventory of the guest OS itself. For VMs where VMware Tools features such as time sync and snapshot quiescing are not required, removing the toolset entirely eliminates the attack surface and simplifies the inventory.

Risks or limitations: The most common mistake is treating guest OS toolsets as background infrastructure software that does not need the same patch urgency as the guest OS itself. Because the toolset communicates directly with the hypervisor and runs with elevated guest OS privileges, a vulnerability in the toolset is operationally closer to a hypervisor vulnerability than to a standard application vulnerability. The best practice is to include toolset version in the VM inventory, track it in the patch management system, and apply updates with the same priority applied to OS-level patches.

Practical Applications

The following scenarios illustrate how virtual network, storage, and guest toolset security principles apply in professional cloud security practice.

Designing Security Visibility for Intra-Host VM Traffic

A cloud security architect at a financial services company is redesigning the network monitoring architecture for a private cloud environment hosting twelve application workloads on four ESXi host servers. The current architecture places the network IDS on the physical switch uplinks, which means the security team has no visibility into VM-to-VM traffic that stays within a single host. She designs a monitoring architecture that configures port mirroring on each ESXi host's virtual switch, directing a copy of all inter-VM traffic to a dedicated monitoring VM running a network analysis sensor on each host. The monitoring VMs forward alert data to the centralised SIEM. She also configures micro-segmentation rules in the virtual switch port groups to enforce that web-tier VMs can only initiate connections to application-tier VMs on TCP 8080 and 8443, and application-tier VMs can only reach database VMs on TCP 5432. No other VM-to-VM paths are permitted. She verifies both changes by running a traffic generation test from each VM tier and confirming both that the monitoring VM captures the traffic and that prohibited paths are blocked and logged.

Responding to the ESXiArgs Ransomware Pattern in a Private Cloud Environment

A cloud security manager at a managed hosting company reads the February 2023 ESXiArgs ransomware advisory and immediately assesses whether the company's 27 ESXi hosts are exposed. She checks the ESXi version across all hosts and confirms that 11 are running versions affected by CVE-2021-21974. She raises an emergency change request to patch all affected hosts within 48 hours. While the patching is in progress, she implements a compensating control: blocking external network access to port 427 (the OpenSLP service port targeted by the exploit) at the perimeter firewall and at the management VLAN ACL, so the vulnerability cannot be reached from outside the management network. She also audits the backup configuration for all 11 affected hosts and finds that three of them store their daily VM snapshots on a network share mounted through the ESXi management interface rather than through an isolated backup path. She moves those backup targets to isolated storage that is not accessible through the ESXi management plane before the patching window, ensuring that a successful attack on those hosts would not immediately encrypt the backup copies along with the live disks.

Implementing a Guest OS Toolset Inventory and Patch Process

A cloud operations security engineer at a SaaS company performs an audit of VMware Tools installations across 340 guest VMs and discovers that 73 VMs are running versions more than two major releases behind the current version, 18 VMs have VMware Tools installed but the service is stopped, and 12 VMs cannot be inventoried because they have no toolset installed but the VM configuration suggests they should. He creates a remediation plan in three tiers: critical update for the 73 VMs running outdated versions with known CVEs, configuration review for the 18 VMs where the service is stopped to determine whether the toolset is needed or should be removed, and audit of the 12 unresolvable VMs to determine their provisioning status and whether they should be decommissioned. He integrates VMware Tools version data into the company's vulnerability management platform so that future toolset versions are tracked alongside OS patches and application libraries in the same remediation workflow, eliminating the previous gap where toolset updates were handled ad hoc rather than through the formal patch management process.

Best Practices

- **Configure virtual switch guest-facing ports in access mode, never trunk mode, and explicitly assign native VLAN IDs.** Trunk mode on guest-facing ports is the root condition enabling VLAN hopping. Access mode restricts each port to a single assigned VLAN and makes double-tagging attacks ineffective. Explicitly assign native VLAN IDs to all trunk uplinks using a VLAN number that is not used for any production traffic,

preventing native VLAN stripping attacks. Verify this configuration annually and after any virtual switch configuration change.

- **Configure port mirroring on virtual switches to make east-west intra-host traffic visible to security monitoring tools.** Security tools positioned only on physical network uplinks cannot see traffic between VMs on the same virtual switch. Port mirroring to a monitoring VM on each host is the standard mechanism for extending monitoring visibility into the virtual network layer. Verify that monitoring coverage includes all virtual switch port groups, not just the uplink to the physical network, and that the monitoring VM's alerts flow into the centralised SIEM.
- **Apply encryption to virtual disk files at the storage backend level and treat snapshot files as having the same sensitivity as live disk files.** Snapshot files contain a complete copy of the VM's disk and memory state at the point of capture. They require the same access control and encryption policies as live virtual disks. Implement automated snapshot retention policies that remove snapshots older than the defined retention period, and audit snapshot file access permissions quarterly to ensure no unintended access paths exist.
- **Include guest OS toolset version in the VM inventory and patch management programme, treated with the same priority as OS-level patches.** Guest OS toolsets communicate directly with the hypervisor through a channel that bypasses network controls. A vulnerability in the toolset is closer in impact to a hypervisor vulnerability than to an application vulnerability. Track installed version in the vulnerability management platform, apply updates under the same SLA as OS patches, and remove the toolset from VMs where its functions are not required.
- **Store VM backup and snapshot copies on storage not accessible through the compromised hypervisor management plane.** The ESXiArgs attack demonstrated that ransomware operators target virtual disk files at the storage layer. Backup copies stored on paths accessible through the same management interface that an attacker controls will be encrypted along with live disks. Backup storage should be isolated from the hypervisor management plane through separate network paths, separate authentication, or offline/immutable storage mechanisms.

Common Mistakes and Misconceptions

Misconception: Assuming physical network segmentation prevents VM-to-VM communication when VMs share the same virtual host, missing the east-west traffic path that never reaches the physical network.

Correct approach: Implement virtual switch port groups with VLAN assignment and micro-segmentation policies to enforce network separation at the virtual layer. Verify with traffic testing that prohibited VM-to-VM paths are blocked, and configure port mirroring to make intra-host traffic visible to monitoring tools.

Misconception: Configuring virtual switch ports in trunk mode for operational flexibility, creating the VLAN hopping vulnerability on guest-facing ports.

Correct approach: Configure all guest VM-facing virtual switch ports in access mode, assigning each port explicitly to a single VLAN. Use trunk mode only on verified uplinks between virtual switches or to physical switches, and explicitly set native VLAN IDs on all trunk ports to non-production VLANs.

Misconception: Storing VM backup snapshots on storage accessible through the same hypervisor management interface, making backups as vulnerable as live disks to storage-layer attacks.

Correct approach: Route backup and snapshot copies to isolated storage with separate authentication paths not accessible through the hypervisor management plane. Test backup recovery from isolated storage periodically to confirm both isolation and recoverability.

Misconception: Treating guest OS toolsets as non-critical background software excluded from the formal patch management programme.

Correct approach: Track guest OS toolset versions in the VM inventory and vulnerability management platform. Apply toolset updates under the same patch SLA as OS-level patches, and remove the toolset from VMs where its functions are not needed to eliminate unnecessary attack surface.

table: Virtual Infrastructure Security Controls: Layer-by-Layer Reference

Use this table to verify that security controls are in place at each virtualisation abstraction layer. Each row represents a distinct security boundary that requires its own controls, independent of controls at other layers.

Layer	Key Risk	Required Control	Verification Method	Common Gap
Virtual NIC / vSwitch	East-west intra-host traffic bypasses physical network monitoring	Port mirroring to monitoring VM; VLAN segmentation at virtual switch level	Generate test traffic between VMs on same host; verify monitoring VM captures it and SIEM receives alerts	Monitoring positioned only on physical uplinks with no visibility into intra-host traffic
Virtual Switch VLAN Config	VLAN hopping through trunk mode on guest-facing ports	Guest-facing ports in access mode; explicit native VLAN assignment on all trunk ports	Attempt double-tagged frame injection from a test VM; verify frames do not reach target VLAN	Trunk mode on guest-facing ports left for operational convenience
Virtual Disk Files	Data remnance on deprovisioning; unauthorised access to disk files; ransomware targeting disk files directly	Disk encryption at storage backend; verify provider's secure deletion process; restrict storage management interface access	Request provider's data deletion documentation; verify encryption is enabled for all new disk provisioning	Assuming provider handles secure deletion without verifying the process
VM Snapshots	Snapshot files contain full disk state; sit outside normal access control if retention is unmanaged	Same access controls and encryption as live disks; automated retention policy removing old snapshots; backup copies on isolated storage	Audit snapshot file permissions quarterly; test recovery from isolated backup storage	Long-lived snapshots accumulating unreviewed; backup snapshots on same storage as live disks
Guest OS Toolsets	Privileged hypervisor communication channel exploitable if toolset is unpatched; runs elevated in guest OS	Current version tracked in inventory; updates applied on OS patch SLA; removed from VMs not requiring integration features	Query all VMs for toolset version; compare against current vendor release; flag any gaps in patch management platform	Toolset excluded from patch management as background infrastructure

How to use this: Review each row during annual cloud security assessments and after any virtualisation platform version change. Rows with gaps in the Verification Method column represent controls that are declared but unverified and should be prioritised for testing.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A security analyst is investigating a lateral movement incident in a private cloud environment. The attacker moved from a compromised web server VM to a database VM on the same physical ESXi host. No alerts were generated on the IDS, which is positioned on the physical network uplinks. Which configuration change would have given the security team visibility into this traffic?

- A) A. Deploying an additional firewall between the web and database VLANs on the physical network.
- B) B. Configuring port mirroring on the virtual switch to direct a copy of inter-VM traffic to a monitoring VM on the same host.
- C) C. Enabling full packet capture on the ESXi management interface.
- D) D. Installing a host-based IDS on the database VM to monitor inbound connections.

Answer: B. Configuring port mirroring on the virtual switch to direct a copy of inter-VM traffic to a monitoring VM on the same host.

Q2. A virtual switch administrator configures guest VM-facing port groups in trunk mode for operational flexibility, allowing VMs to be moved between VLANs without port reconfiguration. Which attack does this configuration most directly enable?

- A) A. ARP spoofing between VMs on the same VLAN.
- B) B. VLAN hopping through double-tagged Ethernet frames targeting VLANs the attacker's VM should not be able to reach.
- C) C. DNS poisoning of the virtual switch's MAC address table.
- D) D. Virtual machine escape through the trunk mode configuration.

Answer: B. VLAN hopping through double-tagged Ethernet frames targeting VLANs the attacker's VM should not be able to reach.

Q3. The ESXiArgs ransomware campaign in 2023 encrypted virtual machine files directly on the ESXi storage backend rather than targeting individual guest operating systems. Which of the following best describes why this approach was particularly effective?

- A) A. ESXi does not support encryption of virtual disk files, leaving them unprotected.
- B) B. By targeting the storage layer beneath the guest OS, the attackers could simultaneously encrypt all VMs on an affected host without compromising each guest OS individually.
- C) C. The attack bypassed hypervisor security controls because it targeted physical storage hardware directly.
- D) D. The attack was effective because ESXi stores virtual disk files in a format that cannot be encrypted by ransomware.

Answer: B. By targeting the storage layer beneath the guest OS, the attackers could simultaneously encrypt all VMs on an affected host without compromising each guest OS individually.

Q4. A VMware Tools vulnerability is disclosed that could allow a malicious actor with guest OS access to send crafted messages through the VMware Tools communication channel toward the hypervisor. What characteristic of this channel makes patching particularly urgent?

- A) A. The VMware Tools channel transmits data in plaintext, making it susceptible to interception on the guest VM network.
- B) B. The VMware Tools channel communicates directly with the hypervisor without generating network traffic, bypassing network-based security controls that would otherwise detect exploitation.
- C) C. The VMware Tools channel requires administrator privileges on the guest OS, limiting the attack surface to privileged users only.

D) D. Exploitation of the VMware Tools channel would only affect the single VM where the exploit originates.

Answer: B. The VMware Tools channel communicates directly with the hypervisor without generating network traffic, bypassing network-based security controls that would otherwise detect exploitation.

Q5. During a cloud security review, an auditor finds that VM snapshot files for a production database server are stored on a network share mounted through the ESXi management interface, and the snapshots have not been reviewed in over 90 days. Which two risks does this finding most directly represent?

A) A. The snapshots may contain outdated database schema that will cause restore failures, and the storage cost is excessive.

B) B. The snapshot files contain the full database disk state and are exposed to storage-layer ransomware attacks through the same management path as live disks, and unreviewed long-lived snapshots accumulate sensitive data outside normal data governance scope.

C) C. The management interface cannot process snapshots older than 30 days, causing silent corruption.

D) D. The snapshot storage share may run out of capacity, causing the database VM to stop responding.

Answer: B. The snapshot files contain the full database disk state and are exposed to storage-layer ransomware attacks through the same management path as live disks, and unreviewed long-lived snapshots accumulate sensitive data outside normal data governance scope.

Reflection Questions

1. Consider a virtualised environment you are familiar with. Does your security monitoring have visibility into east-west traffic between VMs on the same host, or only into traffic that crosses the physical network boundary? What would it take to close that gap?
2. The ESXiArgs campaign targeted virtual disk files at the storage layer without compromising individual guest operating systems. Does your backup architecture ensure that backup copies cannot be reached through the same management path that an attacker with hypervisor access would use?
3. Guest OS toolsets like VMware Tools are installed on VMs across most virtualised environments but rarely appear in formal vulnerability management programmes. Is the toolset version tracked in your VM inventory, and are updates applied under a defined patch SLA?
4. VLAN hopping through trunk mode misconfiguration is a finding that appears regularly in penetration test reports for virtualised environments. When was the last time the virtual switch configuration in your environment was reviewed specifically for guest-facing port mode settings?
5. Each virtualisation abstraction layer, virtual NIC, virtual switch, virtual disk, virtual snapshot, guest toolset, represents a separate security boundary. Which of these boundaries in your current environment has the least formal security control coverage, and why?

Key Takeaways

- Virtual NICs and virtual switches create east-west traffic between VMs on the same host that never touches physical network monitoring infrastructure; port mirroring on virtual switches is required to make this traffic visible to security tools.
- VLAN hopping exploits trunk mode configuration on guest-facing virtual switch ports; the mitigation is to configure all guest VM-facing ports in access mode and explicitly assign native VLAN IDs on all trunk links.
- Virtual disk files, including snapshots, contain the same sensitive data as live systems and must have equivalent access controls, encryption, and retention policies.

- The 2023 ESXiArgs ransomware campaign encrypted virtual disk files directly on the ESXi storage backend, simultaneously affecting all VMs on targeted hosts and demonstrating that backup copies must be stored on paths inaccessible through the compromised hypervisor management plane.
- Guest OS toolsets such as VMware Tools and Hyper-V Integration Services communicate directly with the hypervisor through a channel that bypasses network controls, making their vulnerabilities operationally closer in impact to hypervisor vulnerabilities than to standard application vulnerabilities.
- Each virtualisation abstraction layer, virtual network, virtual storage, and guest toolset, is a distinct security boundary requiring its own controls rather than relying on controls at adjacent layers.
- Security practitioners who treat a virtual machine as a black box and only secure the application and guest OS will miss the infrastructure layers beneath it where some of the most impactful vulnerabilities and attacks actually occur.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Review the virtual switch configuration in one environment you have access to and verify that all guest-facing port groups are in access mode, not trunk mode, and that native VLAN IDs are explicitly assigned on all trunk uplinks.
7. Audit the backup storage configuration for your most sensitive virtualised workloads and confirm that backup copies are stored on storage paths that cannot be reached through the primary hypervisor management interface.
8. Query your VM inventory for guest OS toolset version data and identify any VMs running outdated versions with known CVEs; add guest OS toolset version to your vulnerability management tracking if it is not already present.
9. Verify that your security monitoring platform has visibility into east-west intra-host VM traffic by generating a test connection between two VMs on the same host and confirming that the event appears in the SIEM.